

Lab 5: Seguridad en Sistemas de IA

Introducción

En este laboratorio analizaremos la seguridad de sistemas de IA agenticos: aplicaciones que no solo generan texto, sino que también pueden usar herramientas, leer archivos, ejecutar comandos, interactuar con servicios externos y actuar a través de canales de comunicación como Telegram, WhatsApp, Slack o Discord.

El caso de estudio será **OpenClaw**, una plataforma open source para construir asistentes personales de IA autoalojados. OpenClaw ejecuta un *Gateway* que conecta agentes de IA con múltiples canales de comunicación, aplicaciones móviles, herramientas locales, sesiones persistentes, memoria, automatizaciones y otros agentes. En vez de depender de un SaaS centralizado, el usuario corre OpenClaw en su propia máquina, servidor o VPS: sus llaves, sus datos, sus reglas.

OpenClaw nació en noviembre de 2025 como un proyecto de fin de semana originalmente asociado a la idea de un “WhatsApp Relay”/asistente personal. Luego pasó por los nombres Clawd y Moltbot antes de adoptar el nombre OpenClaw en enero de 2026. Desde el comienzo, su atractivo fue también su principal desafío de seguridad: un asistente accesible desde mensajes cotidianos, con acceso a herramientas reales, puede ser extraordinariamente útil, pero también introduce riesgos importantes si usuarios no autorizados, mensajes maliciosos o contenido no confiable logran influir en sus acciones.

A diferencia de laboratorios anteriores, aquí no construiremos un exploit específico contra una aplicación pequeña. En cambio, realizaremos un análisis de seguridad de un sistema real, activo y en evolución. El objetivo es que desarrollen criterio para evaluar sistemas de IA con herramientas, definir modelos de amenaza razonables y proponer despliegues seguros en contextos empresariales.

Objetivos de aprendizaje

Al completar este laboratorio, deberías ser capaz de:

- Describir la arquitectura básica de un sistema de IA agentic autoalojado.
- Identificar superficies de ataque introducidas por canales de mensajería, herramientas, memoria, automatización y ejecución remota.
- Comparar la evolución de seguridad de un proyecto open source a partir de documentación, código, issues, commits y notas de versión.
- Distinguir entre controles de seguridad, mitigaciones parciales y límites reales del modelo de confianza.
- Definir un modelo de amenaza para una instalación empresarial de un asistente de IA.
- Diseñar una configuración de despliegue que reduzca el riesgo sin destruir la utilidad del sistema.

Material de referencia

Para este laboratorio, revisa al menos las siguientes fuentes:

- Sitio principal: <https://openclaw.ai>
- Documentación: <https://docs.openclaw.ai>
- Repositorio: <https://github.com/openclaw/openclaw>
- Guía de seguridad: <https://docs.openclaw.ai/gateway/security>
- Arquitectura y configuración: <https://docs.openclaw.ai/concepts/architecture> y <https://docs.openclaw.ai/gateway/configuration>
- Sandboxing: <https://docs.openclaw.ai/gateway/sandboxing>
- Historial de commits, releases, issues y pull requests del repositorio.

No es necesario instalar OpenClaw para hacer este laboratorio. Sin embargo, se recomienda instalarlo o explorarlo localmente si quieres probar sus flujos, entender mejor la configuración o experimentar con el *Gateway* y sus controles de seguridad. Si decides instalarlo, hazlo en una máquina o VM donde no haya secretos personales importantes.

Parte 1: Evolución de seguridad de OpenClaw

En esta parte analizarás cómo ha cambiado OpenClaw desde sus primeras versiones hasta su estado actual.

OpenClaw comenzó como un asistente personal conectado a canales de mensajería. Esa idea inicial trae varias preguntas de seguridad:

- ¿Quién puede enviar mensajes al asistente?
- ¿Qué herramientas puede usar el agente cuando recibe un mensaje?
- ¿Qué datos privados pueden quedar disponibles para el modelo?
- ¿Qué ocurre si el mensaje contiene instrucciones maliciosas?

- ¿Qué pasa si el asistente está conectado a grupos, canales compartidos o espacios de trabajo con múltiples usuarios?
- ¿Qué tan fuerte es la separación entre sesiones, usuarios, agentes y máquinas?

Tu tarea es comparar el OpenClaw “original” o temprano con la versión actual. Para ello puedes usar el historial del repositorio, releases, documentación antigua si está disponible, commits relevantes, issues de seguridad, cambios en configuración y páginas actuales de seguridad.

Ejercicio 1: Línea de tiempo de seguridad.

Construye una línea de tiempo breve de la evolución de OpenClaw desde noviembre de 2025 hasta hoy. Incluye hitos relevantes como cambios de nombre, crecimiento del proyecto, incorporación de nuevas superficies de comunicación, aparición de documentación de seguridad, controles de acceso, sandboxing, auditorías, políticas de herramientas u otros cambios que consideres importantes.

No basta con listar fechas: explica por qué cada hito cambia el riesgo del sistema o mejora su postura de seguridad.

Ejercicio 2: Mejoras concretas.

Identifica al menos **cinco mejoras de seguridad** que existan actualmente en OpenClaw o en su documentación. Para cada una, explica:

- Qué problema intenta resolver.
- Qué amenaza reduce.
- Qué configuración, componente o práctica la implementa.
- Qué limitaciones mantiene.

Ejemplos de áreas que puedes investigar: allowlists, políticas de DM, pairing, control de grupos, **contextVisibility**, perfiles de herramientas, sandboxing, **openclaw security audit**, permisos de archivos, aislamiento por agentes, separación de gateways, manejo de secretos, bloqueo de exposición pública, configuración de ejecución de comandos y políticas de aprobación.

Ejercicio 3: Modelo de confianza declarado.

OpenClaw declara explícitamente que su modelo recomendado es el de un asistente personal o de una frontera de confianza única, no un sistema multi-tenant hostil donde usuarios adversarios comparten el mismo gateway/agente.

Explica qué significa esta afirmación. Luego responde:

- ¿Qué riesgos aparecen si varias personas no completamente confiables pueden enviar instrucciones al mismo agente con herramientas?
- ¿Por qué una **sessionKey** o una sesión separada no necesariamente equivale a autorización fuerte?
- ¿Qué diferencias hay entre aislamiento de contexto, autorización para activar el bot y autorización para usar herramientas?

Parte 2: Riesgos que aún existen

Un sistema puede mejorar mucho y aun así seguir siendo riesgoso. En esta parte analizarás los problemas que permanecen abiertos o que son inherentes a los sistemas de IA con herramientas.

Ejercicio 4: Superficies de ataque actuales.

Enumera y describe al menos **seis superficies de ataque** relevantes en una instalación moderna de OpenClaw. Para cada una, indica un ejemplo de abuso posible y una mitigación razonable.

Considera, entre otras:

- Mensajes directos desde canales externos.
- Grupos o canales compartidos.
- Prompt injection y contenido no confiable.
- Herramientas de ejecución (**exec**, procesos, nodos remotos).
- Navegador, scraping, cookies y sesiones autenticadas.
- Memoria persistente y transcripciones.
- Cron jobs, webhooks y automatizaciones.
- Plugins, skills y cadena de suministro.
- Paired nodes en móviles o computadores.
- Exposición del Gateway, dashboard o interfaces web.

Ejercicio 5: Prompt injection no es “solo prompt injection”.

OpenClaw conecta modelos de lenguaje con acciones reales. Discute por qué una instrucción maliciosa en un correo, página web, documento o mensaje de chat puede ser más peligrosa cuando el agente tiene acceso a herramientas.

Luego analiza al menos tres escenarios donde una prompt injection podría llevar a consecuencias concretas, como filtración de información, modificación de archivos, envío de mensajes, ejecución de comandos, alteración de memoria o abuso de credenciales.

Ejercicio 6: Límites de las mitigaciones.

Elige tres controles de seguridad de OpenClaw y explica cómo podrían fallar o ser insuficientes si se configuran mal o si se usan fuera de su modelo de confianza. Por ejemplo:

- Un allowlist abierto a demasiados usuarios.
- Un gateway compartido por varias áreas con datos incompatibles.
- Herramientas peligrosas habilitadas para un agente que recibe mensajes de grupos.
- Un navegador autenticado con cuentas personales y usado por un agente empresarial.
- Sandboxing desactivado o asumido erróneamente.
- Plugins instalados sin revisión.

Parte 3: Diseño de una instalación empresarial segura

Ahora aplicarás tu análisis a un caso práctico.

Imagina que trabajas como consultor/a de seguridad para **Andes Health Analytics**, una empresa mediana que desarrolla software y análisis de datos para clínicas. La empresa quiere instalar OpenClaw para mejorar la productividad de sus equipos internos.

La empresa tiene:

- Un equipo de ingeniería con acceso a repositorios privados, CI/CD y servidores de staging.
- Un equipo comercial que usa Gmail, Google Drive, Slack y un CRM con información de clientes.
- Un equipo de operaciones que coordina tareas por WhatsApp y Telegram.
- Documentos internos con contratos, facturas, información financiera y datos personales.
- Algunos datos sensibles de salud usados en proyectos de analítica, que no deberían ser visibles para toda la empresa.
- Varios usuarios que quieren asistentes personales, pero también un bot compartido para soporte interno.
- Interés en automatizar tareas: resumir correos, crear tickets, consultar documentos, revisar repositorios, calendarizar reuniones, generar reportes y ejecutar scripts simples.

La gerencia pregunta: “¿Podemos instalar OpenClaw para toda la empresa? ¿Cómo lo haríamos de forma segura?”

Ejercicio 7: Modelo de amenaza.

Define un modelo de amenaza para este escenario. Debe incluir:

- Activos a proteger.
- Tipos de usuarios y niveles de confianza.
- Atacantes plausibles internos y externos.
- Canales de entrada no confiables.
- Acciones peligrosas que el sistema podría ejecutar.
- Impactos posibles: confidencialidad, integridad, disponibilidad, cumplimiento y reputación.

Sé específico. No basta con decir “un atacante podría robar datos”. Explica qué datos, por qué canal, usando qué capacidad y con qué consecuencia.

Ejercicio 8: Arquitectura propuesta.

Diseña una arquitectura de despliegue para OpenClaw en Andes Health Analytics. Tu propuesta debe indicar:

- Cuántos gateways usarías y por qué.
- Si separarías por usuario, equipo, sensibilidad de datos o ambiente.
- Dónde correrían los gateways: laptop, servidor interno, VM, contenedor, VPS, etc.
- Qué cuentas de Google/Slack/GitHub/CRM usaría cada agente.
- Qué herramientas estarían habilitadas para cada tipo de agente.
- Qué sesiones, memorias y workspaces deberían mantenerse separados.
- Qué controles de red aplicarías.
- Cómo manejarías secretos, tokens y credenciales.

Justifica tus decisiones usando el modelo de confianza de OpenClaw. En particular, discute por qué una sola instalación compartida por toda la empresa podría ser problemática.

Ejercicio 9: Configuración y controles.

Propón una configuración de seguridad concreta. Puedes escribirla como pseudoconfiguración, fragmentos JSON o una tabla. Debe incluir medidas como:

- Políticas de DM y grupos.
- Allowlists o pairing.
- Reglas para menciones en grupos.
- Restricciones de herramientas.
- Sandboxing para sesiones no principales.
- Políticas para `exec` y comandos elevados.
- Separación de perfiles de navegador.
- Uso de cuentas de servicio o cuentas dedicadas.
- Auditorías periódicas con `openclaw security audit`.
- Revisión de plugins y skills.
- Logging y redacción de datos sensibles.
- Procedimientos de actualización.

Explica qué ataques mitiga cada control.

Ejercicio 10: Plan operacional.

La seguridad no termina al instalar el sistema. Propón un plan operacional para mantener OpenClaw seguro durante seis meses. Incluye:

- Proceso de onboarding y offboarding de usuarios.
- Revisión periódica de allowlists y permisos.
- Rotación de credenciales.
- Monitoreo de logs y eventos anómalos.
- Gestión de incidentes.
- Evaluación de nuevos plugins o herramientas.
- Actualización de modelos y dependencias.
- Criterios para decidir cuándo un agente necesita su propio gateway o máquina.

Entregables

Entrega un informe en Markdown o PDF con las siguientes secciones:

1. **Resumen ejecutivo:** principales riesgos y recomendaciones.
2. **Línea de tiempo de seguridad de OpenClaw.**
3. **Mejoras de seguridad identificadas.**
4. **Riesgos residuales y superficies de ataque.**
5. **Modelo de amenaza para Andes Health Analytics.**
6. **Arquitectura de despliegue propuesta.**
7. **Configuración y controles recomendados.**
8. **Plan operacional de seis meses.**
9. **Conclusión:** qué tan apropiado es OpenClaw para este escenario y bajo qué condiciones.

Tu informe debe ser claro, técnico y argumentado. Puedes incluir diagramas, tablas, fragmentos de configuración y referencias a documentación o commits específicos.

Criterios de evaluación

Se evaluará:

- Calidad del análisis técnico.
- Uso correcto de conceptos de seguridad: modelo de amenaza, superficie de ataque, aislamiento, privilegios mínimos, defensa en profundidad y riesgo residual.
- Capacidad para distinguir entre controles reales y supuestos incorrectos.
- Evidencia tomada de documentación, repositorio, commits, issues o configuración.
- Claridad y factibilidad de la arquitectura propuesta.
- Profundidad del análisis de prompt injection y herramientas.

- Calidad de la escritura y organización del informe.

Notas finales

No se espera que demuestres una vulnerabilidad nueva ni que ataques sistemas reales. Si encuentras un problema de seguridad potencial en OpenClaw, trátalo responsablemente: no publiques exploits funcionales contra usuarios reales, no accedas a datos ajenos y reporta siguiendo los canales apropiados del proyecto.

El objetivo de este laboratorio es aprender a pensar como arquitectos de seguridad para sistemas de IA: no basta con preguntar si “el modelo responde bien”; hay que analizar quién puede hablarle, qué puede hacer, qué datos ve, qué herramientas controla y qué ocurre cuando algo sale mal.